Регистрация. Предварительный процесс

Сценарии:

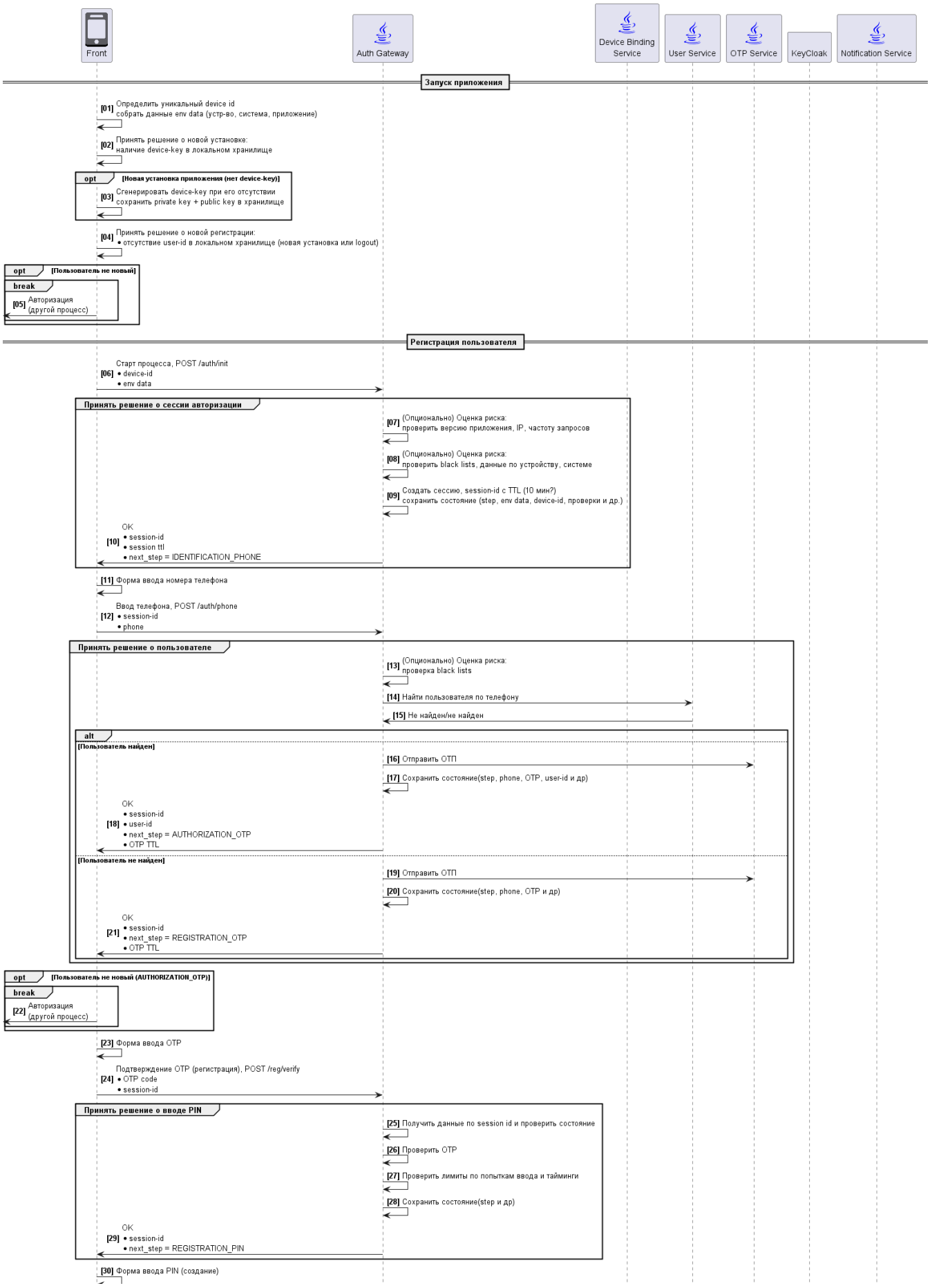
- первая установка приложения, пользователь не зарегистрирован
- регистрация второго пользователя в установленном приложении

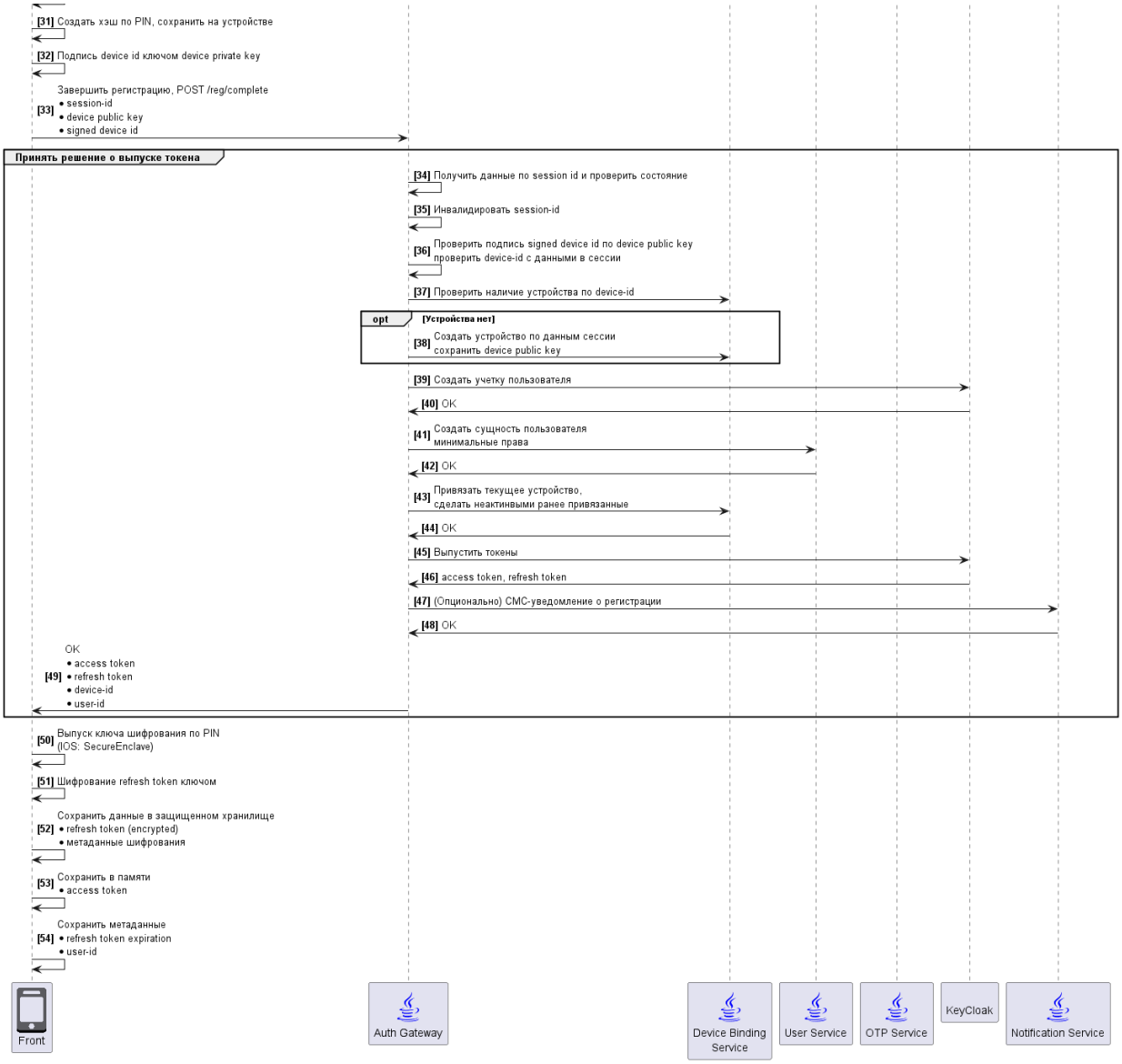
Plant UML

```
@startuml

!include <tupadr3/devicons/java>
!include <aws/General/mobileclient/mobileclient>
!include <tupadr3/devicons/database>
!include <tupadr3/devicons/codepen>
!include <tupadr3/devicons/redis>

participant "<$mobileclient>\nFront" as frontend
participant "<font color=blue><$java>\nAuth Gateway" as auth
participant "<font color=blue><$java>\nDevice Binding\nService" as device
participant "<font color=blue><$java>\nUser Service" as user
participant "<font color=blue><$java>\nOTP Service" as otp
participant "<font color=blue>\nKeyCloak" as idp
participant "<font color=blue><$java>\nNotification Service" as notification


autonumber "<b>[00]"
==   ==

  frontend -> frontend:   device id\n  env data (-, , )

  frontend -> frontend:     :\n device-key

  opt    ( device-key)
    frontend -> frontend:  device-key   \n private key + public key
  end opt

  frontend -> frontend:     :\n* user-id    (   logout)

  opt
    break
      frontend ->[:\n( )
    end break
  end opt

==   ==
  frontend -> auth:  , POST /auth/init\n*device-id\n*env data
  group
    auth -> auth: ()  : \n  , IP,
    auth -> auth: ()  : \n black lists,   ,

    auth -> auth:  , session-id  TTL (10 ?)\n  (step, env data, device-id,   .)

    auth -> frontend: OK\n*session-id\n*session ttl\n*next_step = IDENTIFICATION_PHONE
  end

  frontend -> frontend:
  frontend -> auth:  , POST /auth/phone\n*session-id\n*phone
  group

    auth -> auth: ()  :\n black lists

    auth -> user:
    user -> auth:  /
    alt
      else
```

```
      auth -> otp:
      auth -> auth:  (step, phone, OTP, user-id  )
      auth -> frontend: OK\n*session-id\n*user-id\n*next_step = AUTHORIZATION_OTP\n*OTP TTL
    else
      auth -> otp:
      auth -> auth:  (step, phone, OTP  )
      auth -> frontend: OK\n*session-id\n*next_step = REGISTRATION_OTP\n*OTP TTL
  end
end

opt    (AUTHORIZATION_OTP)
  break
    frontend ->[:\n( )
  end break
end opt

  frontend -> frontend:   OTP
  frontend -> auth:  OTP (), POST /reg/verify\n*OTP code\n*session-id
  group     PIN
    auth -> auth:    session id
    auth -> auth:  OTP

    auth -> auth:

    auth -> auth:  (step  )

    auth -> frontend: OK\n*session-id\n*next_step = REGISTRATION_PIN

  end

  frontend -> frontend:   PIN ()
  frontend -> frontend:    PIN,
  frontend -> frontend:  device id  device private key

  frontend -> auth:  , POST /reg/complete\n*session-id\n*device public key\n*signed device id
  group
    auth -> auth:    session id

    auth -> auth:  session-id

    auth -> auth:   signed device id  device public key\n device-id

    auth -> device:     device-id
    opt
      auth -> device:     \n device public key
    end

    auth -> idp:
    idp -> auth: OK

    auth -> user:   \n
    user -> auth: OK

    auth -> device:   ,\n
    device -> auth: OK

    auth -> idp:
    idp -> auth: access token, refresh token

    auth -> notification: () -
    notification -> auth: OK

    auth -> frontend: OK\n*access token\n*refresh token\n*device-id\n*user-id

  end

  frontend -> frontend:     PIN\n(IOS: SecureEnclave)
  frontend -> frontend:  refresh token
  frontend -> frontend:     \n*refresh token (encrypted)\n*
  frontend -> frontend:   \n*access token
  frontend -> frontend:  \n*refresh token expiration\n*user-id
```

```
@enduml
```


Front
Auth Gateway
Device Binding Service
User Service
OTP Service
KeyCloak
Notification Service
Запуск приложения
[01] Определить уникальный device id
собрать данные env data (устр-во, система, приложение)
[02] Принять решение о новой установке:
наличие device-key в локальном хранилище
opt [Новая установка приложения (нет device-key)]
[03] Сгенерировать device-key при его отсутствии
сохранить private key + public key в хранилище
[04] Принять решение о новой регистрации:
• отсутствие user-id в локальном хранилище (новая установка или logout)
opt [Пользователь не новый]
break
[05] Авторизация
(другой процесс)
Регистрация пользователя
Старт процесса, POST /auth/init
[06] • device-id
• env data
Принять решение о сессии авторизации
[07] (Опционально) Оценка риска:
проверить версию приложения, IP, частоту запросов
[08] (Опционально) Оценка риска:
проверить black lists, данные по устройству, системе
[09] Создать сессию, session-id с TTL (10 мин?)
сохранить состояние (step, env data, device-id, проверки и др.)
OK
[10] • session-id
• session ttl
• next_step = IDENTIFICATION_PHONE
[11] Форма ввода номера телефона
Ввод телефона, POST /auth/phone
[12] • session-id
• phone
Принять решение о пользователе
[13] (Опционально) Оценка риска:
проверка black lists
[14] Найти пользователя по телефону
[15] Не найден/не найден
alt
[Пользователь найден]
[16] Отправить ОТП
[17] Сохранить состояние(step, phone, OTP, user-id и др)
OK
[18] • session-id
• user-id
• next_step = AUTHORIZATION_OTP
• OTP TTL
[Пользователь не найден]
[19] Отправить ОТП
[20] Сохранить состояние(step, phone, OTP и др)
OK
[21] • session-id
• next_step = REGISTRATION_OTP
• OTP TTL
opt [Пользователь не новый (AUTHORIZATION_OTP)]
break
[22] Авторизация
(другой процесс)
[23] Форма ввода OTP
Подтверждение OTP (регистрация), POST /reg/verify
[24] • OTP code
• session-id
Принять решение о вводе PIN
[25] Получить данные по session id и проверить состояние
[26] Проверить OTP
[27] Проверить лимиты по попыткам ввода и тайминги
[28] Сохранить состояние(step и др)
OK
[29] • session-id
• next_step = REGISTRATION_PIN
[30] Форма ввода PIN (создание)


[31] Создать хэш по PIN, сохранить на устройстве
[32] Подпись device id ключом device private key
[33] Завершить регистрацию, POST /reg/complete
• session-id
• device public key
• signed device id
Принять решение о выпуске токена
[34] Получить данные по session id и проверить состояние
[35] Инвалидировать session-id
[36] Проверить подпись signed device id по device public key
проверить device-id с данными в сессии
[37] Проверить наличие устройства по device-id
opt
[Устройства нет]
[38] Создать устройство по данным сессии
сохранить device public key
[39] Создать учетку пользователя
[40] OK
[41] Создать сущность пользователя
минимальные права
[42] OK
[43] Привязать текущее устройство,
сделать неактивными ранее привязанные
[44] OK
[45] Выпустить токены
[46] access token, refresh token
[47] (Опционально) СМС-уведомление о регистрации
[48] OK
[49] OK
• access token
• refresh token
• device-id
• user-id
[50] Выпуск ключа шифрования по PIN
(IOS: SecureEnclave)
[51] Шифрование refresh token ключом
[52] Сохранить данные в защищенном хранилище
• refresh token (encrypted)
• метаданные шифрования
[53] Сохранить в памяти
• access token
[54] Сохранить метаданные
• refresh token expiration
• user-id
Front
Auth Gateway
Device Binding Service
User Service
OTP Service
KeyCloak
Notification Service